

Document title	Risk Treatment Plan
Document ID	SLP-ISMS-008
Version	1.0
Classification	Internal
Owner	ISMS Manager
Approved by	Peter Kováč, Managing Director
Date	20 February 2026

DISCLAIMER: SLOVPACK s.r.o. is a fictional company created for portfolio purposes. All data, names and scenarios are invented.

1. Purpose

This Risk Treatment Plan addresses all risks rated **High** in the Risk Register (SLP-ISMS-007), together with selected **Medium** risks where treatment is mandated by customer requirements or is low-cost to implement. Each treatment applies the option selected in the Risk Register (Modify / Share) and is mapped to the relevant Annex A controls. Progress is reviewed quarterly and reported at management review.

Budget figures are indicative estimates pending supplier quotations.

2. Treatment Table

Risk	Treatment	Controls	Owner	Budget	Target	Status
RSK-001	Enforce MFA tenant-wide for all M365 accounts; deliver quarterly phishing awareness training; enable M365 anti-phishing policies	5.17, 8.5, 6.3, 8.7	M. Urban	€0 (licence incl.) + 8 h	31 Mar 2026	Completed
RSK-010	Fit a lock on the server room with restricted key	7.1, 7.2, 7.4	P. Kováč	€150	31 Mar 2026	Completed

	issuance; introduce a visitor log at reception; remove key from the kitchen board					
RSK-012	Introduce mandatory callback verification for any supplier bank-account change; brief the finance team on BEC/invoice fraud	5.14, 6.3, 8.7	J. Šimková	€0	31 Mar 2026	Completed
RSK-002	MSP contract addendum: quarterly patching + quarterly restore tests with written reports; activate immutable cloud backup tier; design network segmentation	8.8, 8.13, 8.22, 5.29	M. Urban / MSP	€3,500 + monthly fees	30 Apr 2026	In progress
RSK-018	Convert 3 shared WMS accounts to individual accounts (licence renegotiation with LogisSoft); add warehouse onboarding/of fboarding checklist	5.16, 5.17	L. Hruška	€40 / month	15 May 2026	In progress
RSK-013	Block consumer cloud storage via M365	5.10, 5.14, 8.12	K. Bieliková	€0 + 6 h	31 May 2026	In progress

	policy; provide OneDrive/SharePoint sharing training to sales; pilot DLP alerting					
RSK-007	Restrict HR/payroll data access to Finance & HR Manager and payroll accountant; enforce MFA on PayWell; start records of processing	5.18, 5.34, 8.5	J. Šimková	€0	31 May 2026	Planned
RSK-009	MSP contract addendum: named individual technician accounts, MFA on RMM, 24 h incident notification, right to audit; restrict scope of MSP access	5.20, 5.21, 8.2, 8.5	ISMS Manager	€0 (contractual)	31 May 2026	Planned
RSK-003	Contract addendum with WebFront (security requirements, secure coding, annual pen test); commission first external penetration test of the e-shop	8.29, 8.26, 5.20, 8.30	K. Bielíková	€2,800 (pen test)	31 May 2026	Planned
RSK-016	Enable M365 audit log	8.15, 8.16,	M. Urban	€0–500	30 Jun 2026	Planned

	retention; centralise ERP logs; define a minimal monitoring and evidence-collection runbook	5.28				
RSK-004	Redesign ERP roles so recipes are visible only to production leads and MD; introduce quarterly access reviews; add offboarding asset checklist	5.18, 8.3, 5.11, 6.5	R. Čech	€0 + 16 h	30 Jun 2026	Planned
RSK-020	Create records of processing activities (GDPR Art. 30); establish a personal-data breach assessment and 72 h notification process; retire obsolete 2018 legal directive	5.31, 5.34, 5.24	J. Šimková	€0 (internal effort)	30 Jun 2026	Planned

3. Monitoring and Review

Treatment progress is tracked in the ISMS action log and reviewed quarterly by the ISMS Manager. Completed treatments are verified during internal audits (SLP-ISMS-010/011). Residual risk after treatment is recorded in the Risk Register (SLP-ISMS-007) and accepted by the Managing Director where it remains at Medium or above.

